# 2. Assessment Objectives and Scope

## 2.1 Assessment Purpose

The purpose of this assessment was to identify, analyze, and document cybersecurity vulnerabilities within a controlled virtualized laboratory environment and demonstrate how technical findings can be translated into structured IT security risks.

The assessment was conducted using Greenbone Community Edition against an intentionally vulnerable Metasploitable Linux virtual machine hosted on Proxmox Virtual Environment (VE).

The project combined technical vulnerability assessment with risk management and internal control concepts commonly applied in IT auditing, cybersecurity governance, and technology risk management.

The assessment was designed for educational and professional portfolio purposes. It was not performed on a production system or on behalf of an external organization.

## 2.2 Assessment Objectives

The assessment had six primary objectives:

1. **Identify technical vulnerabilities.** Use Greenbone Community Edition to detect vulnerabilities, insecure configurations, weak authentication mechanisms, and exposed services on the target system.

2. **Evaluate vulnerability severity.** Review scanner-generated findings, including CVSS severity ratings and Quality of Detection (QoD) values, to understand the technical significance and strength of the reported evidence.

3. **Assess potential business risks.** Translate significant technical vulnerabilities into business-oriented risk statements using a simulated production scenario and a five-point likelihood and impact scoring methodology.

4. **Identify relevant security controls.** Map documented risks to applicable NIST SP 800-53 controls and consider their relationship to the COSO Internal Control Framework.

5. **Develop risk treatment recommendations.** Document proposed remediation actions, simulated risk owners, treatment priorities, and validation methods.

6. **Communicate assessment results.** Prepare a risk register, risk scoring methodology, risk treatment plan, executive dashboard, and formal risk assessment report suitable for management-level review.

## 2.3 Assessment Environment

The assessment was conducted within a Proxmox VE 9.0.3 virtualized laboratory environment.

The laboratory consisted of a Greenbone vulnerability scanner and a deliberately vulnerable Metasploitable target system.

### Laboratory System Inventory

| Component | Configuration | Purpose |
|---|---|---|
| Virtualization Platform | Proxmox VE 9.0.3 | Hosts the laboratory virtual machines |
| Proxmox Host | `pve-01` | Laboratory virtualization server |
| Vulnerability Scanner | Greenbone Community Edition | Identifies and reports technical vulnerabilities |
| Scanner VM | Ubuntu 24.04, VM 121 | Hosts the Greenbone scanning environment |
| Target VM | Metasploitable, VM 120 | Intentionally vulnerable assessment target |
| Target IP Address | `10.10.50.10` | System assessed for vulnerabilities |
| Scanner Lab IP Address | `10.10.50.20` | Scanner interface used to reach the target |
| Scanner Management IP | `192.168.1.154` | Management access to the scanner |
| Laboratory Subnet | `10.10.50.0/24` | Network used for vulnerability assessment traffic |

The Greenbone scanner was configured with two network interfaces: one connected to the laboratory network and another used for management connectivity.

The Metasploitable virtual machine was connected to the laboratory network and did not have a configured default gateway.

The laboratory bridge, `vmbr3`, was configured without a physical network uplink. IP forwarding was disabled on the scanner, and firewall forwarding restrictions were configured to reduce the risk of unintended traffic between networks.

These measures supported the intended separation of the vulnerable target from the home network. However, complete network isolation was not independently established through comprehensive verification of every possible forwarding path.

## 2.4 Assessment Scope

The technical assessment was limited to the Metasploitable virtual machine at IP address `10.10.50.10`.

Greenbone Community Edition was used to identify vulnerabilities affecting services and software exposed by this target.

The completed scan reported:

| Technical Severity | Number of Results |
|---|---|
| Critical | 13 |
| High | 8 |
| Medium | 39 |
| Low | 6 |
| **Total** | **66** |

The detailed risk analysis focused on the **13 Critical Greenbone results**.

Two scan results associated with the same vsftpd backdoor vulnerability were consolidated into a single risk, producing **12 distinct entries** in the IT Security Risk Register.

The registered risks covered the following security areas:

- Remote command execution and unauthorized system access
- Backdoor services and potentially compromised software
- Weak, missing, or default authentication credentials
- Unsupported operating systems and vulnerable applications
- Insecure remote administration services
- Application connector configuration weaknesses
- Database authentication and privileged access

The remaining High, Medium, and Low scanner findings were included in the overall assessment statistics but were not individually analyzed or entered into the 12-risk register.

## 2.5 Activities Included in Scope

The following activities were included in the assessment:

| Assessment Activity | Scope |
|---|---|
| Laboratory Configuration | Establish the Proxmox-based scanner and target environment |

| Assessment Activity | Scope |
|---|---|
| Vulnerability Identification | Conduct a Greenbone vulnerability scan against the target |
| Finding Review | Examine the 13 Critical scanner results |
| Evidence Analysis | Review available detection details and reported test results |
| Risk Identification | Consolidate findings into 12 distinct security risks |
| Inherent Risk Assessment | Apply provisional likelihood and impact ratings under a simulated production scenario |
| Control Mapping | Identify relevant COSO components and NIST SP 800-53 controls |
| Risk Treatment Planning | Recommend corrective actions, priorities, and validation methods |
| Management Reporting | Develop a risk register, treatment plan, dashboard, and assessment report |

The technical assessment included scanner-generated active checks. Some checks demonstrated unauthorized access or command execution, while other findings were based on software versions, service exposure, or vulnerability detection logic.

A scanner finding was not treated as proof of successful exploitation unless the available evidence supported that conclusion.

## 2.6 Activities Excluded from Scope

The following activities were not performed as part of this assessment:

1. **Production environment testing:** No production systems, enterprise applications, or external organizational networks were assessed.

2. **Comprehensive penetration testing:** The project did not attempt to exploit every identified vulnerability or conduct a full penetration test.

3. **Organizational control testing:** No formal evaluation of security policies, control design, or control operating effectiveness was performed.

4. **Remediation implementation:** Vulnerabilities were documented, but corrective actions were not implemented on the intentionally vulnerable target.

5. **Remediation validation:** No follow-up scan was conducted to verify that vulnerabilities had been resolved.

6. **Residual risk assessment:** Residual risk was not calculated because remediation and compensating control effectiveness had not been evaluated.

7. **Formal management approval:** Risk acceptance decisions, treatment approvals, and remediation deadlines were not obtained from an actual organization.

8. **Detailed analysis of non-Critical findings:** The eight High, 39 Medium, and six Low scanner results were not individually assessed in the risk register.

These exclusions establish the boundaries of the assessment and prevent unsupported conclusions about the security posture of an actual organization.

## 2.7 Business Risk Assessment Assumptions

To demonstrate how vulnerability findings can inform enterprise risk management, a hypothetical production scenario was established.

For this scenario, the affected server was assumed to support business applications and be accessible from an internal corporate network.

Potential consequences were evaluated in terms of unauthorized access, system compromise, information disclosure, data modification, and operational disruption.

Likelihood and impact were scored using a five-point scale, with inherent risk calculated as:

**Inherent Risk Score = Likelihood × Impact**

The resulting scores were classified as Low, Medium, High, or Critical according to the documented Risk Scoring Methodology.

These ratings are provisional and illustrative. They do not represent approved risk assessments for an actual organization or the operational risk of the isolated laboratory environment.

Similarly, the assigned risk owners and treatment priorities are simulated for the purposes of demonstrating governance and accountability.

## 2.8 Assessment Deliverables

The assessment produced the following deliverables:

| Deliverable | Purpose |
|---|---|
| Greenbone Vulnerability Scan Report | Provides the underlying technical vulnerability findings |
| IT Security Risk Register | Documents 12 distinct risks and their supporting evidence |
| Risk Scoring Methodology | Defines likelihood, impact, and risk classification criteria |

| Deliverable | Purpose |
|---|---|
| Risk Treatment Plan | Documents recommended remediation, priorities, ownership, and validation methods |
| Executive Dashboard | Summarizes technical findings and provisional business-risk ratings |
| IT Security Risk Assessment Report | Communicates the assessment approach, findings, limitations, and recommendations |

Together, these deliverables provide an auditable record of how the identified technical vulnerabilities were reviewed, assessed, prioritized, and communicated.

## 2.9 Scope Conclusion

The assessment scope was intentionally limited to a single vulnerable virtual machine within a controlled laboratory environment.

This approach allowed the project to demonstrate the complete process of identifying technical vulnerabilities, evaluating their potential business significance, mapping relevant controls, and documenting proposed risk treatment actions.

The resulting analysis supports cybersecurity education and professional portfolio development. It does not constitute a security assurance opinion regarding any production organization or environment.